

An Attack Risk Assessment Model for Network Security Automation

Candidate: Francesca Coriale

Supervisors: prof. Daniele Brighenti, prof. Fulvio Valenza,
prof. Riccardo Sisto

1 Introduction and Motivation

In today's landscape, large-scale systems are becoming increasingly complex due to the rising number of connected devices and evolving user demands, which create a more dynamic and challenging security environment. The heterogeneity of network devices complicates vulnerability detection, and the variety of attack types further challenges effective management. As a result, network security is crucial to neutralize these threats with adequate defense. Specifically, automation was proposed in literature to improve network security reconfiguration, to minimize human intervention, ensure scalability and flexibility, and guarantee the formal correctness of the solution.

In this context, when distributed security functions undergo a series of configuration changes, the transition from the first change to the last may expose temporary, insecure states. Each state may involve deploying or removing virtual functions or updating their rules, and the time needed for these operations is often non-negligible. This gap can lead to service disruptions, undetected intrusions, and exploitation of temporary vulnerabilities. To address this problem, the *FATO* (*Firewall Transients Optimizer*) approach was introduced to automatically schedule intermediate reconfiguration stages for the most commonly used network security function, i.e., the packet-filtering firewall, aiming to minimize insecure states and reduce the time the system remains at risk.

However, the main limitation of FATO is that the reconfiguration changes are prioritized depending on user's preferences expressed for connectivity policies. Instead, the evolution of modern attacks, increasingly more sophisticated with combinations of vectors, has highlighted the need to define a prioritization based on the impact of each attack event. To this end, risk assessment models play a central role, providing structured and verifiable priorities for different attacks by considering factors like economic, reputational, and operational impact, attack frequency, and the effectiveness of existing defense systems.

After these considerations, the objective of this thesis is to provide a semi-quantitative analysis of the risk associated with each vector or stage of the attack to define the corresponding priority values and maximize the number of secure states in the transient. To do so, a new model for the reconfiguration of packet filter firewalls in large-scale networks has been studied and validated as part of the FATO approach in a critical infrastructure scenario.

2 Contributions of the thesis

The primary objective of this thesis is to bridge the gap between risk assessment and network security automation for cyberattack mitigation, setting the stage for more adaptive and resilient security strategies.

To achieve this objective, the major contribution has been the design of a novel approach that readjusts traditional risk assessment models to guide not only strategic planning but also operational reactions to complex attacks. Specifically, a new semi-quantitative risk assessment model, inspired by the methodologies proposed by NIST and Open FAIR, was defined. Rather than relying entirely on either framework, this model simplifies and aligns selected aspects to support automation and real-time response, enabling fast prioritization of threats while preserving a meaningful representation of risk.

The FATO methodology was then enhanced by integrating this risk assessment model, enabling risk-based firewall reconfiguration strategies tailored to each attack scenario. By linking the estimated severity and impact of ongoing attack patterns to reconfiguration priorities, this enhanced approach can determine the optimal scheduling of the firewall reconfiguration changes, ensuring the most critical ones are executed first and reducing exposure to insecure stages during transients.

3 The Risk Assessment Model

The proposed solution is illustrated in Figure 1. The risk assessment process is structured into three main phases: calculating the *Impact*, analyzing the *Likelihood*, and evaluating the *Risk level*.

3.1 Impact Value

Following the NIST definition, the impact of a threat event is the magnitude of harm expected from unauthorized malicious actions. It is thus tied to the economic and reputational worth of the victim node (*Asset Value*), the severity of the exploited vulnerability (*Exploitation Severity*), and the operational degradation caused by the attack (*Attack Strength*).

The *Asset Value* represents the worth of any data, device, or other component of the environment that can be illicitly accessed, used, or stolen, resulting in economic

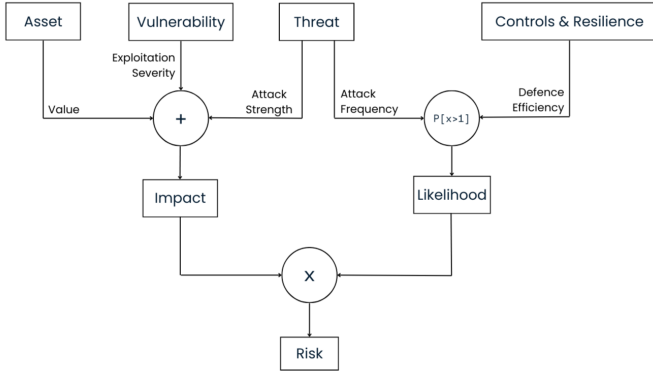


Figure 1: Attack Risk Model

and reputational loss. It can be defined in two ways: by applying an internal parameter developed by the organization, the “Business Impact Score”, or by relying on external sources estimating asset values. The Business Impact Score evaluates the impact of different incidents or attacks on the organization’s performance and can be computed through a *Business Impact Analysis (BIA)*, whose goal is to ensure the continuous availability of resources needed to sustain critical business functions. However, not all organizations can conduct a complete BIA on their own, and in such cases they may rely on external statistical information and empirical studies such as IBM’s *Cost of Data Breach Report*.

The *Exploitation Severity* represents the damage that exploiting a specific vulnerability in the system can cause. To calculate this parameter, organizations can rely on the internationally recognized CVSS framework, which evaluates vulnerabilities through three metric groups: Base, Temporal, and Environmental. Only the first is publicly shared, describing the inherent characteristics of a vulnerability that remain unchanged over time and assuming the reasonable worst-case impact across environments. It produces a score from 0 to 10 indicating the severity of a vulnerability relative to others. If a CVSS score is not available, or when no CVE has yet been identified, organizations may rely on qualitative, empirical evaluation expressed as low, medium, or high, and then mapped to symbolic values from 0 to 10. A useful example is the pre-compiled table proposed by NIST for analyzing vulnerabilities.

The *Attack Strength* represents the suffering of the node in terms of percentage of CPU and memory used. Since many services operate near their performance limits under normal conditions, even a modest increase in demand during an attack can cause significant degradation or unavailability. To express the degree to which the attack stresses the system beyond its ordinary workload, the formula (1) computes this parameter as the ratio between the resources typically used in daily operations and those consumed during the incident.

$$\delta = \frac{\text{attack} - \text{normal}}{\text{threshold} - \text{normal}} \quad (1)$$

Since delta is a real number between 0 and 1, its value

must be scaled to 0–10 to align with the other parameters.

Finally, the formula (2) computes the Impact value as a weighted sum of factors, where weights are chosen by the user between 0 and 1 that sum to 1.

$$\begin{aligned} \text{Impact} = & w_1 \cdot \text{Asset Value} + \\ & w_2 \cdot \text{Exploitation Severity} + \\ & w_3 \cdot \text{Attack Strength} \end{aligned} \quad (2)$$

3.2 Likelihood Value

In the Open FAIR model, Likelihood expresses how often a Loss Scenario is expected to occur within a given timeframe. Recurrence matters in optimizing network re-configurations because some attacks, though not severe, are so simple that they can be repeated indefinitely in short intervals, destabilizing the system and preventing the resolution algorithm from concluding.

The *Attack Frequency* parameter reflects the number of times an attacker successfully exploited the threat event and performed the attack. It can be derived from internal sources, such as historical records and databases of previous incidents, or from external sources such as Verizon’s annual *Data Breach Investigations Report*.

The *Defence Efficiency* measures how well the monitoring and protection systems already in place can limit the effects of an attack. It is included because the recurrence of attacks is closely tied to the level of damage they cause. Attackers tend to repeat strategies that consistently succeed, while techniques easily blocked by defenses lose appeal. Therefore, this parameter captures the idea that adversaries act based on their perceived success, influencing how frequently attacks are expected to occur.

Finally, the Likelihood value expresses the probability that the same attack will recur in the future, taking into account the defenses already in place. This probability is calculated using the *Poisson distribution*, a discrete distribution that estimates how many events occur in a fixed period of time, assuming a known average rate and independence from the last event (3).

$$f(\lambda; k) = P[X = k] = \frac{\lambda^k e^{-\lambda}}{k!} \quad (3)$$

Here, λ is defined as the average Attack Frequency. Considering only past occurrences ignores existing defenses and implicitly assumes every attack has the same chance of success, which is unrealistic. Thus, the frequency must be adjusted to reflect only attacks that bypass controls, by introducing $(1 - \text{Defense Efficiency})$, which represents the proportion of attacks able to evade security measures.

Then, as we need to know the probability that the attack event will occur at least once in the interval of one year, the Poisson equation becomes as follows:

$$\begin{aligned} P[X > 0] = & 1 - P[X = 0] = 1 - e^{-\lambda} = \\ & 1 - e^{-(1 - \text{Defense Efficiency})} \end{aligned} \quad (4)$$

Due to the exponential nature of the result, the value lies between 0 and 1 and, to maintain consistency with the Impact scale, the Likelihood is rescaled to a range from 0 to 10 and rounded to two decimal places.

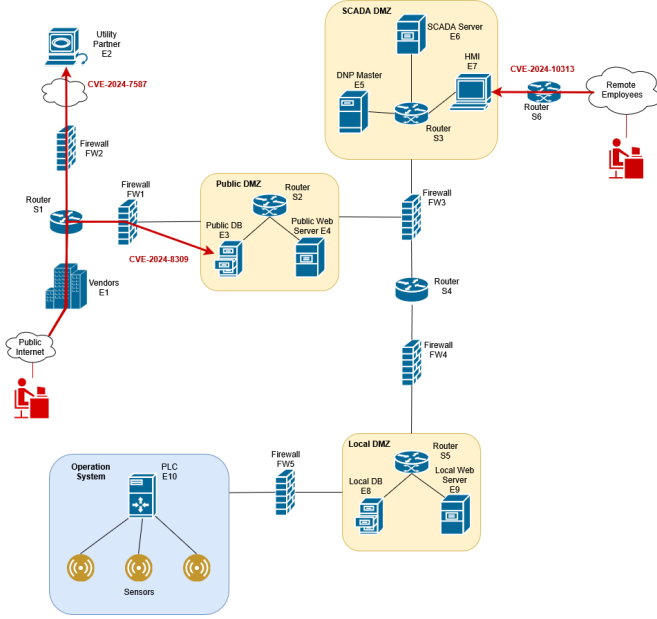


Figure 2: SCADA testbed

3.3 Risk Level

Finally, the *Risk Level* is computed as the product of the Impact and Likelihood values.

$$\text{Risk} = \text{Impact Value} \times \text{Likelihood Value} \quad (5)$$

The two factors are both defined within a range from 0 to 10, therefore their combination produces risk levels between 0 and 100. The outcome represents both the impact of a single attack, or a stage of a multi-step attack, and the frequency with which it may reoccur. Consequently, at equal frequency, an attack that severely exploits system vulnerabilities will generate a higher risk level than one with limited effects. On the contrary, a less damaging attack occurring very frequently will produce a greater risk level than a stronger but rare attack.

4 Implementation and Validation

The risk assessment model was integrated in the implementation of the FATO approach. It was then validated by reproducing a real SCADA environment and injecting real-world vulnerabilities documented in the field in 2024, as shown in Figure 2. Three main types of attacks were simulated: Distributed Denial of Service (DDoS), data exfiltration, and privilege escalation, targeting the Utility Partner node, the Public Database, and the HMI interface, respectively. For each of the attack scenarios the parameters involved in the formulation of Impact and Likelihood are derived from external sources and plausible hypotheses, where the lack of a real physical system made it impossible to take reliable data. For the computation of the Impact value, the Asset Value and the Exploitation Severity values are retrieved from the IBM Cost of Data Breach report and the CVSS framework, respectively. The Attack Strength is estimated based on the

expected strength of the attacks mentioned above, as the real effects on the physical system cannot be retrieved, and the values for the attack scenarios are 9, 3, 3, respectively. The resulting values are combined with different weight combinations.

For the computation of the Likelihood value, the Verizon Data Breach Investigations Report details Attack Frequency data investigated over 10.000 organizations. As all the attack scenarios exploit some kind of vulnerability, the percentage of occurrence for the three attacks is roughly 1.978 events with a mean rate of 0.198 for each organization. The hypothetical values for the Defense Efficiency parameter are assumed based on plausible considerations and measures already present in the system. The final results are 0.4 for the Utility Partner scenario and 0 for the Public Database and HMI scenarios.

The summary of the outcomes, assuming 0.33 as weight for each parameter in the computation of the Impact values for all attacks, is as following:

- for the attack to the Utility Partner, the Impact is 6.9, the Likelihood is 1.1, thus the risk level is 7.6;
- for the attack to the Public Database, the Impact is 4.3, the Likelihood is 1.8, thus the risk level is 7.7;
- for the attack to the HMI, the Impact is 5.6, the Likelihood is 1.8, thus the risk level is 10.1.

This result shows how relying only on the impact score could overlook the temporal danger of attacks, as an event with moderate impact but higher likelihood may be more critical than one with high impact but low likelihood. By combining Impact and Likelihood, the assessment produces a more realistic view of the threat landscape, and the resulting risk levels guide protective measures by ensuring efforts are prioritized effectively.

5 Conclusions and Future Work

This thesis develops a risk-driven approach to optimize the automatic reconfiguration of firewalls during multi-vector and multi-stage attacks. Integrated into the FATO approach, it enhances the scheduling of reconfiguration steps to maximize secure states and improve responsiveness. A semi-quantitative model, combining elements from NIST and Open FAIR, calculates the risk of each attack using parameters such as Asset Value, Exploitation Severity, Attack Strength, and recurrence probability. Validated on a realistic SCADA testing ground with real-world vulnerabilities, the approach shows its ability to adapt to different organizational priorities and deliver structured, verifiable prioritization of reconfiguration actions.

As future work, the proposed risk assessment model can be applied to other automation approaches, such as methods for broader network reconfiguration or attack graph analysis, and can be extended to capture interdependencies among attack paths. Moreover, the model can be enhanced by embedding live feeds from threat intelligence platforms.